

EE-482: Network Security and Cryptography

LECTURE NO 16: *Kerberos Authentication Protocol*

Engr. Tehseen Ahsan

**Assistant Professor, Computer Engineering Department
HITEC University Taxila Cantt, Pakistan**

Organization of Lecture

1. Kerberos Authentication Protocol
 - i. Kerberos Version 4 Authentication Protocol
 - ii. Kerberos Version 5 Authentication Protocol
2. Rationale for the elements of Kerberos Version 4 Protocol

6. Kerberos Authentication Protocol (1/13)

In the modern world of communication, Internet plays a vital role. But the major threat in Internet is many malicious users try to get unencrypted password communicated over the Internet with sniffing tools. With the different authentic services like Kerberos, X.509 and Public Key Infrastructure (PKI), only legitimate users will be allowed to access the intended services.

Kerberos

- Kerberos is an authentication protocol, which allows clients to communicate over a non-secure network environment based on the use of 'tickets' in order to prove their identity to one another in a secure manner. It is designed primarily for a client-server communication to provide mutual authentication by which the client and the server can verify each other's identity in a secure manner. Hence, Kerberos authentication protocol gives protection against eavesdropping and replay attacks. Kerberos relies on the use of trusted third party during authentication and it is based on symmetric key cryptography.*

6. Kerberos Authentication Protocol (2/13)

Kerberos

- Massachusetts Institute of Technology (MIT) developed the Kerberos Authentication Service for Project Athena. Initial versions of Kerberos were used within the MIT. From Kerberos, Version 4 is widely used outside the MIT. Version 4 developed for Project Athena could not provide the functionalities that are required universally. Therefore, Version 5 was developed which could overcome the shortcomings of Version 4.

Kerberos Terminologies

The following are the terminology or conventions that are used in Kerberos authentication service.

- Client*: An entity who initiates the communication.
- Authentication Server*: An entity who verifies the identity of the client.
- Ticket*: It is a proof by which the client identifies itself to the server.

6. Kerberos Authentication Protocol (3/13)

Kerberos Terminologies

- iv. *Plaintext*: The actual text intended by the user to send as a message.
- v. *Encryption*: The process of converting the plaintext to a meaningless form so that the attacker cannot realize the actual content of the message.
- vi. *Ciphertext*: With the help of encryption mechanism, the plaintext is converted to ciphertext.
- vii. *Decryption*: Retrieving the original plaintext from the ciphertext.
- viii. *A secret-key cryptosystem*: A single key called secret key is used for encryption and decryption.
- ix. *A public-key cryptosystem*: A key pair, namely, public and private key is used for encryption and decryption, respectively.

6. Kerberos Authentication Protocol (4/13)

1. A simple Authentication Protocol:

- If a network is not protected, any client can obtain unauthorized privileges from any server which leads to a security risk of impersonation. To counter this threat, the servers are required to authenticate the clients before providing the service.
- An authentication Server (AS) stores the passwords of all users in a centralized database. In addition to that, a unique secret key is shared between the AS and each server physically or in some other secure manner.

6. Kerberos Authentication Protocol (5/13)

1. *A simple Authentication Protocol:*

- Consider the following simple protocol:

Step 1:

When the user (*u*) first logs on to the workstation, the client (*C*) module of the workstation sends a request message to *AS* which includes the user's identity (*UID*), the user's password (*UP*) and the server's identity (*SID*).

$$C \rightarrow AS : UID \parallel UP \parallel SID$$

6. Kerberos Authentication Protocol (6/13)

1. *A simple Authentication Protocol:*

Step 2:

The AS verifies the user's identity and its corresponding password in its database. If it holds, AS generates a ticket for the client which has the *UID*, network address (*NA*) and the *SID*. After generating the ticket, the ticket (*T*) is encrypted by the shared secret key (*SSK*) known to the *AS* and the server (*S*). Then the AS sends *T* to *C*. The main aim of encrypting *T* is to prevent from its alteration or forgery by an opponent.

$$AS \rightarrow C : T$$

$$T = E_{SSK}(UID \parallel NA \parallel SID)$$

Step 3:

By using this *T*, the *C* can send a request to *S* for service. The request message of *C* contains *UID* and *T*. Once the *S* receives the request message, it decrypts *T* and verifies *UID* in the ticket with unencrypted *UID* in the request message. If both are same, then *S* considers that the user is authenticated and gives the requested service.

$$C \rightarrow S : T \parallel UID$$

6. Kerberos Authentication Protocol (7/13)

2. The Kerberos Version 4 Authentication Protocol

- The simple authentication protocol contains various problems. *First problem with the foregoing scenario is that the servers have not authenticated themselves to users.* Without such authentication, an opponent/attacker can configure a false server in a different location to act as a real server so that messages from the user to a server were directed to different location.
- *Second problem is that each user is asked to enter the password for accessing various services from various servers.* For example, if the user wants to access mail server in the morning, file server in the afternoon and print server in the evening, then the user has to enter the same User Password (*UP*) three times.

6. Kerberos Authentication Protocol (8/13)

2. The Kerberos Version 4 Authentication Protocol

- In such cases, opponent may get a greater opportunity to capture the password. Finally for getting, different services from different servers, different tickets are required in simple authentication protocol. These problems can be eliminated by introducing a new server called as Ticket Provider (*TP*).
- The Kerberos version 4 authentication protocol is explained in Figure 1 next slide and the six steps involved in this diagram are explained as follows.

Step 1: The *C* sends a message to the *AS* requesting access to the ticket provider (*TP*). The *TP*, provides tickets to authenticated users from the *AS*. The request message of *C* contains *UID*, the *TP* identity (*TPID*), and the time stamp (*ts*).

$$C \rightarrow AS : UID \parallel TPID \parallel ts1$$

6. Kerberos Authentication Protocol (9/13)

2. *The Kerberos Version 4 Authentication Protocol*

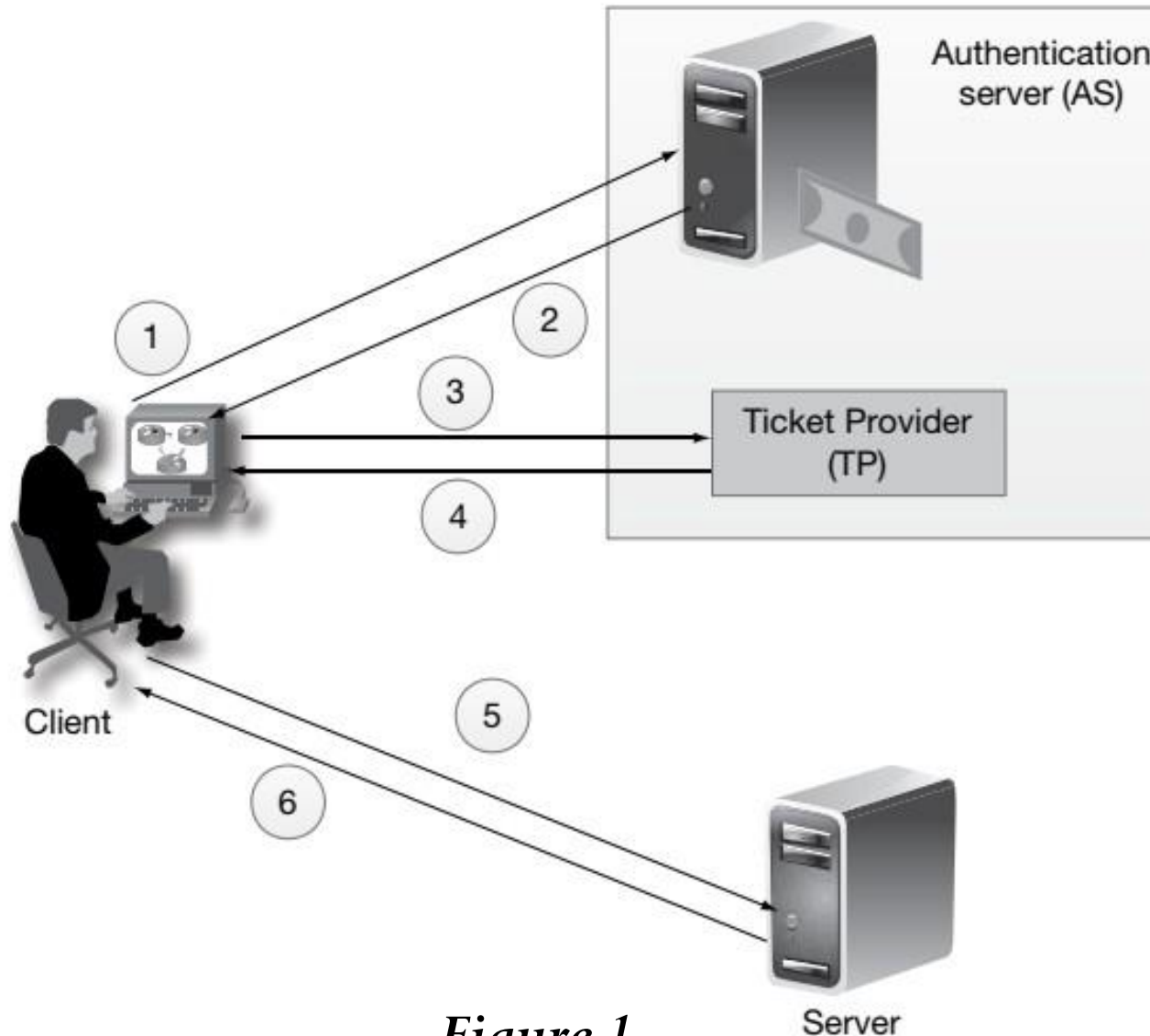


Figure 1

6. Kerberos Authentication Protocol (10/13)

2. The Kerberos Version 4 Authentication Protocol

Step 2: After receiving this message, the *AS* generates a secret key (*SK*) from the *UP*, a session key (*SEK*) and the ticket (*TTP*) to communicate with *TP*. The ticket is encrypted using the *TP*'s secret key (*STP*). The *AS* responds to *C* with a message, encrypted using *SK* as shown below:

$$AS \rightarrow C : E_{SK} (SEK \parallel UID \parallel ts2 \parallel lifetime2 \parallel TTP)$$

$$TTP = E_{STP} (SEK \parallel UID \parallel NA \parallel TPID \parallel ts2 \parallel lifetime2)$$

Step 3: The message is then decrypted by *C* using its *SK* and then the session key and *TTP* are taken to approach the *TP*. For that, *C* sends a message to *TP* that includes the *TTP* plus the *SID*. In addition to that, *C* transmits an *Authen message*, which contains the ID of *C*'s user and a timestamp.

$$C \rightarrow TP : SID \parallel TTP \parallel Authen\ message$$

Where $Authen\ message = E_{SEK} (UID \parallel NA \parallel ts3)$, which is used only once and it is not reusable unlike the ticket. This has a short life time.

6. Kerberos Authentication Protocol (11/13)

2. The Kerberos Version 4 Authentication Protocol

Step 4: The *TP* then gets the *SEK* by decrypting *TTP* using its *STP* which it shared between the *TP* and the *AS*.

$$TTP = D_{STP}(E_{STP}(SEK \parallel UID \parallel NA \parallel TPID \parallel ts2 \parallel lifetime2))$$

Then, the *TP* uses the *SEK* to decrypt the *Authen message*. The *TP* can then verify the user identity and network address from the *Authen message* with that of the ticket *TTP* and network address with incoming message. If all are matched, then the *TP* is assured that the user is the authenticated user. Then *TP* sends a message to *C* by encrypting it using the session key shared between *TP* and *C*. The *TP* includes a session key (*SEKS*) to be shared between *C* and the server *S*, *SID*, the timestamp and the ticket (*TTS*) used for a server through which a client can communicate with the server.

$$TP \rightarrow C : E_{SEK}(SEKS \parallel SID \parallel ts4 \parallel TTS)$$

$$TTS = E_{SKS}(SEKS \parallel UID \parallel NA \parallel SID \parallel ts4 \parallel lifetime4)$$

Where *SKS* is the secret key of the server.

6. Kerberos Authentication Protocol (12/13)

2. *The Kerberos Version 4 Authentication Protocol*

Step 5: After receiving the message, the C decrypts the certificate using the session key SEK and gets the following.

$$(SEKS \parallel SID \parallel ts4 \parallel TTS)$$

Then, the C sends a message to server which includes the ticket TTS and a *Authen message1*.

$$C \rightarrow S : TTS \parallel \textit{Authen message1}$$

Where $\textit{Authen message1} = E_{SEKS}(UID \parallel NA \parallel ts5)$

Step 6: The server can decrypt the ticket TTS using its secret key SKS , and gets the session key $SEKS$, and decrypt the *Authen message1*. Then S increment the timestamp by one for mutual authentication and finally, the client and server share a secret key for future message communications.

$$S \rightarrow C : E_{SEKS}(ts5 + 1)$$

6. Kerberos Authentication Protocol (13/13)

3. The Kerberos Version 5 Authentication Protocol

- Kerberos Version 4 was developed to use in the MIT campus and later expanded to the world outside. To provide security mechanism in Kerberos, DES algorithm was mainly used. So, the weakness of DES impacted a lot in running Version 4 universally. In Version 5, it is overcome by allowing other encryption algorithms to use.
- In Kerberos Version 4, Single authentication request-response. whereas in Version 5, Multi-step authentication process.
- Version 5 has the capability of supporting different types of network address whereas Version 4 supports only Internet Protocol. Thus, Version 5 claims major advantages in the areas of security, authentication and interoperability over Version 4.

7. Rationale for the elements of Kerberos Version 4 Protocol (1/3)

Message 1/step 1

UID: User ID

TPID: Token Provider Identity

ts1: Allows AS to verify that client's clock is synchronized with that of AS.

Message 2/step 2

SEK: Session Key generated by AS for the secure communication of C & TP.

ts2: Informs client of time this ticket was issued.

lifetime 2: Informs client of lifetime of this ticket (lifetime of ticket TTP).

TTP: Token to communicate with Token Provider (TP).

SK: Secret key generated by AS for the secure communication between AS & C.

STP: Secret Key of Token Provider

NA: Network Address

7. Rationale for the elements of Kerberos Version 4 Protocol (2/3)

Message 3/step 3

SID: Server ID

ts3: Informs time stamp of time the "Authen message" was created.

Message 4/step 4

SEKS: Session key to be shared between c & s.

TTS: Ticket to communicate with server.

ts4: Informs client of the time this ticket (TTS) was issued

lifetime 4: Informs client of lifetime of this ticket (TTS)

SKS: Secret key of the server.

7. Rationale for the elements of Kerberos Version 4 Protocol (3/3)

Message 5/step 5

ts_5 : Informs Server of time the Authn message 1 was created

Message 6/step 6

E_{SEKs} : Secret key shared by client (C) & Server (S) for future communication.

ts_{5+1} : Assures C that this is not a replay of an old reply

References: Textbooks

1. *“Cryptography and Network Security”, by Behrouz A. Forouzan, Debdeep Mukhopadhyay, 2nd Edition, McGraw Hill Education (India) Private Limited.*
2. *“Cryptography and Network Security Principles and Practice”, by William Stallings, 6th Edition, Pearson.*
3. *“Computer Security Principles and Practice”, by William Stallings, Lawrie Brown, 4th Edition, Pearson.*